

LAB GUIDELINES

Lab 25 — Secure Decommissioning and Media Destruction

Maps to CompTIA Server+ objective **3.6 — Summarize proper server decommissioning concepts** (proper removal procedures — company policies, verify non-utilisation, documentation — asset management, change management; media destruction — disk wiping, physical: degaussing, shredding, crushing, incineration; purposes for media destruction; media retention requirements; cable remediation — power, networking; electronics recycling — internal vs. external, repurposing).

Run all commands on <https://killercoda.com/playgrounds/scenario/ubuntu>

Required software (free, apt): coreutils (shred, dd), wipe, nwipe, secure-delete

```
apt update && apt install -y wipe nwipe secure-delete
```

> ■ All commands target a **loopback file**. Never run shred/dd/nwipe against a real disk you intend to keep.

Step 1 — Decommission workflow checklist

```
[ ] Confirm with stakeholders no service still depends on this server (verify non-utilisation)
[ ] Open a change ticket (Lab 17) with rollback plan
[ ] Schedule downtime, notify users
[ ] Drain from load balancer / cluster (Lab 14)
[ ] Final backup → tested restore (Lab 26) → off-site copy
[ ] Capture as-built docs to the asset record (Lab 17)
[ ] Power off
[ ] Wipe media (this lab)
[ ] Physical destruction or repurposing (this lab)
[ ] Update CMDB: status = retired, asset tag returned
[ ] Cable remediation: pull patch cables, label removed PDU strips
[ ] Issue certificate of destruction to records
```

Step 2 — Create a "drive" with sensitive content

```
truncate -s 50M /srv/oldserver.img
mkfs.ext4 /srv/oldserver.img
mkdir -p /mnt/old && mount -o loop /srv/oldserver.img /mnt/old
echo "customer_pii: jane@example.com / SS 555-12-1234" > /mnt/old/pii.txt
echo "db_credential: prod_root: H@ckMe!" >> /mnt/old/pii.txt
sync && umount /mnt/old
strings /srv/oldserver.img | grep -E "pii|cred" | head
```

You can read the secrets out of the raw image — that's the threat.

Step 3 — Logical wipe with `shred` (single-pass)

```
shred -v -n 1 -z /srv/oldserver.img
strings /srv/oldserver.img | grep -E "pii|cred" | head || echo "no plaintext recoverable"
```

-n 1 = one random-data pass, -z = final zero pass to look "blank". Single-pass is fine on **modern HDDs**; SSDs need ATA Secure Erase (next step).

Step 4 — Multi-pass wipe with `nwipe` (DoD-style)

```
truncate -s 50M /srv/oldserver.img
nwipe --autonuke --nowait --method=dod /srv/oldserver.img 2>&1 | tail -10
```

--method=dod does the 3-pass DoD 5220.22-M sequence. Other methods: gutmann (35 passes — overkill for modern drives), random, zero.

Step 5 — SSD-specific: ATA Secure Erase

shred-style overwrites are **ineffective** on SSDs because of wear-levelling. Use the drive's own firmware command:

```
# Example (do NOT run on the system disk):
# hdparm --user-master u --security-set-pass NULL /dev/sdX
# hdparm --user-master u --security-erase NULL /dev/sdX
echo "hdparm --security-erase → SSD firmware erases every cell, including spare blocks"
```

For self-encrypting drives (SED), simply destroy the key (cryptographic erase) — milliseconds.

Step 6 — Physical destruction methods (Server+ vocabulary)

Method	What it does	When to use
Degaussing	Strong magnetic field randomises platters	Magnetic HDDs and tapes only — **useless on SSDs**
Shredding	Drive is fed into industrial shredder	Universal, certificate from vendor
Crushing	Hydraulic press	Quick on-site option
Incineration	High-temp furnace	Maximum assurance — used for top-secret

Always pair physical destruction with a **certificate of destruction** including serial number, method, date, witness — file in the asset record.

Step 7 — Purposes for media destruction

Server+ 3.6 lists the **why**:

1. ****Regulatory**** — HIPAA, PCI-DSS, GDPR, PDPA require it.
2. ****Contractual**** — customer / vendor NDA may demand it.
3. ****Risk reduction**** — even non-regulated data can leak credentials.
4. ****End-of-life policy**** — company asset disposal rules.
5. ****Repurposing safety**** — drive going to another team / project starts from blank.

Step 8 — Media retention requirements

Some data must be kept (legal hold, audit retention) **before** destruction. Check the retention matrix from Lab 18 before wiping anything. A `legal_hold` flag in the CMDB blocks destruction until lifted.

Step 9 — Cable remediation

Pulling a server leaves loose cables that become hazards:

```
[ ] Power: trace from server PSU back to PDU outlet, unplug, cap PDU outlet
[ ] Network: pull patch cables at both ends; label removed switch ports as "spare"
[ ] Fibre: cap connectors with dust covers; coil for storage
[ ] Console / KVM: pull and label
[ ] Update rack-layout diagram (Lab 1) and cable map
```

Step 10 — Electronics recycling: internal vs. external

Path	Practice
Internal	Repurpose for test, dev, training — sanitised first
External	Certified e-waste vendor (R2v3 / e-Stewards), tracked chain of custody, certificate of recycling

Never sell drives — even wiped — without a certificate of sanitisation.

Free online tools

- ****NIST SP 800-88 Rev 1**** — Guidelines for Media Sanitization — <https://csrc.nist.gov/publications/detail/sp/800-88/rev-1/final>
- ****DBAN successor: ShredOS / nwipe**** — https://github.com/PartialVolume/shredos.x86_64
- ****R2v3 certified recyclers directory**** — <https://sustainableelectronics.org/>

What you learned

- The full decommission checklist linking change management, asset records, and stakeholder verification.
- Logical wipe (`shred`, `nwipe`) and when it is — or is not — sufficient.
- SSD-specific erase (ATA Secure Erase, crypto-erase) and why software overwrite alone fails.
- Physical destruction vocabulary: degaussing, shredding, crushing, incineration.
- Why media destruction is required (regulatory + risk + repurposing).
- Cable remediation steps after pulling a server.
- Internal vs. external recycling and the certificate trail you must keep.